

Lynis Audit Report: Baseline, Remediation and Final Outcome

Defensive Security Posture Assessment, Attack Surface Reduction, and Operational Availability on plmnsrv

Project Metadata

- **Date:** September 24, 2026
 - **Environment:** Ubuntu Server 24.04 LTS (Kernel 6.8.0, Bare-Metal, Headless)
 - **Base Tool:** Lynis 3.0.9 (CISOfy)
-

1. Executive Summary

This report documents the information security audit and hardening process performed on the residential server named plmnsrv. The main technical objective of the project was the continuous reduction of the operational attack surface on a bare-metal headless server running Ubuntu Server 24.04 LTS, maintaining as a mandatory premise the uninterrupted availability of all network and application services in production (Nextcloud via the LAMP stack, Cockpit, Jellyfin, Pi-Hole, Caddy Reverse Proxy and OpenSSH).

The technical intervention resulted in the evolution of the overall security indicator (Hardening Index) from **75** to **80** points, representing a relative increase of **+6.7%** in the defensive posture of the asset. The single critical alert reported (Warning) was fully mitigated, reducing the metric from **1** to **0**. The total volume of pending recommendations (Suggestions) declined from **40** to **33**, reflecting the expansion of three new test vectors validated in the second cycle. The primary operational milestone was strictly met: zero interruptions or functional instability were recorded in the application services, preserving the operational integrity of both external and internal communication routes.

2. Execution Methodology

The security posture assessment used the audit and compliance software Lynis 3.0.9, executed in deep local system inspection mode – privileged mode (*sudo lynis audit system*). The methodological cycle covered transversal coverage of authentication layers, kernel modules, network daemon configuration, file integrity and continuous process auditing.

In order to safeguard the continuous availability of local services, all findings identified in the baseline audit were cataloged and distributed across three operational decision matrices:

1. **Category A — Remediable Without Impact:** Actions that can be applied immediately without interrupting processes, without requiring a system reboot and without blocking service ports.
2. **Category B — Application at Scheduled Boot:** Structural modifications applied to static configuration files whose effective activation occurs during the normal reboot cycle of the equipment, without inducing immediate production downtime.
3. **Category C — Not Applicable Due to Operational Disruption Risk:** Controls whose implementation would degrade mandatory functionalities (Nextcloud, Jellyfin, Performance Co-Pilot) or would carry a disproportionate risk of access lockout on a headless bare-metal node.

As a safety protocol against failures during execution, all configuration files received prior timestamped backups (.bak). Additionally, mandatory syntax checks (such as *sshd -t*) were tied to graceful daemon reload flows (*systemctl reload*), while parallel OpenSSH administrative sessions were kept open to mitigate the risk of connectivity loss.

3. Indicator Comparison: Before vs. After

The table below summarizes the quantitative results obtained in the initial baseline audit compared with the re-audit cycle executed immediately after the application of the authorized remediations.

Audit Metric	Scan 1 (Baseline)	Scan 2 (Post-Remediation)	Net Change
Hardening Index (Overall)	75	80	+5 (+6.7%)
Critical Alerts (Warnings)	1	0	-1 (-100%)
Recommendations (Suggestions)	40	33	-7 (-17.5%)
Total Tests Performed	274	277	+3 (+1.1%)

4. Remediated Controls and Technical Validation

The interventions performed focused on eliminating common exploitation vectors, strengthening local authentication mechanisms, validating static integrity and adjusting the configuration of exposed daemons.

Lynis Control	Vector / Component	Technical Action Performed	Operational Result
MAIL-8818 / MAIL-8820	Postfix MTA	Hiding of the detailed banner (smtpd_banner) and deactivation of the VRFY command. Graceful reload applied.	Critical alert (Warning) eliminated; user enumeration blocked.
AUTH-9262	PAM Module	Implementation of the libpam-pwquality library with minimum password complexity and length requirements.	Strict entropy requirements applied to new credentials.
AUTH-9286	Login Definitions	Adjustment of password aging in login.defs and application of 'chage' exclusively to the human operator account.	Standardized password lifecycle without impacting daemon accounts.
KRNL-5820	Core Dumps	Blocking of process memory dumps via limits.conf (* hard core 0) and fs.suid_dumpable.	Mitigation of credential leakage via memory dumps.
SSH-7408	OpenSSH Daemon	Adjustment of the ClientAliveCountMax (2) and MaxSessions (2) parameters through a drop-in file in sshd_config.d.	Limitation of idle sessions while keeping the administrative connection stable.

ACCT-9630	Auditd Engine	Creation of rules in audit/rules.d to track changes to accounts (/etc/passwd, shadow) and sudoers.	Audit trail compliant with integrity requirements.
FINT-4350	AIDE Engine	Installation of the AIDE utility, generation of the initial static database and scheduling of daily checks.	Autonomous binary tampering verification mechanism.

5. Kernel Parameter Hardening (KRNL-6000)

The hardening of kernel runtime parameters was applied through the creation of the structured file */etc/sysctl.d/99-hardening.conf*. Parameter activation occurred dynamically through the *sysctl --system* utility, eliminating the need for a hardware reboot and keeping all network sockets and disks in continuous operation.

The following parameters were consolidated into the permanent environment configuration:

- **dev.tty.ldisc_autoload = 0:** Prevents the automatic and arbitrary loading of vulnerable TTY line disciplines.
- **fs.protected_fifos = 2:** Prevents data from being written to third-party FIFOs within shared temporary directories.
- **fs.suid_dumpable = 0:** Blocks the generation of core dumps originating from binaries with the SUID bit active.
- **kernel.core_uses_pid = 1:** Forces the concatenation of the process identifier (PID) to the core dump file names.
- **kernel.perf_event_paranoid = 3:** Severely restricts unprivileged user access to performance tracing subsystems.
- **kernel.sysrq = 0:** Fully disables the low-level kernel magic key control combination.
- **kernel.unprivileged_bpf_disabled = 1:** Restricts the loading and execution of eBPF programs exclusively to the superuser.
- **net.core.bpf_jit_harden = 2:** Activates advanced constant blinding protection against JIT-spraying attacks in the network stack.
- **net.ipv4.conf.all.log_martians = 1:** Enables detailed logging of packets with impossible or spoofed addressing.
- **net.ipv4.conf.default.accept_source_route = 0:** Disables the acceptance of source routing on default network interfaces.

6. Prioritization Matrix for Pending Recommendations

The 33 remaining suggestions pointed out by the audit engine were analyzed under the prism of security criticality versus implementation complexity in the environment, divided into three service horizons.

6.1 High Priority — Quick Actions Without Impact

Immediate sanitation actions, without complex infrastructure dependencies and fully safe for the application stack:

- **BANN-7126 and BANN-7130:** Deployment of legal restricted-use notices in */etc/issue* and */etc/issue.net* to inhibit passive disclosure of the distribution version before authentication.
- **NAME-4402:** Normalization of the */etc/hosts* file through the removal of duplicate entries and guarantee of the plmnsrv host mapping.

- **FINT-4402:** Configuration of the SHA-256 and SHA-512 hash algorithms in the AIDE utility checksum calculation routine.
- **MALW-3286:** Standardization of the autonomous update routine for ClamAV antivirus signatures via freshclam.
- **PKGS-7346:** Controlled removal (purge) of approximately 42 libraries and packages declared orphaned by the APT package manager.
- **PKGS-7410:** Cleanup of old residual kernel image versions via *apt autoremove*, keeping two functional images for safety.

6.2 Medium Priority — Decisions with Risk Management

Recommended technical items, but which require a controlled change window or planned reboot validation:

- **SSH-7408 (Port Change):** Requires prior release in the UFW firewall, change in *sshd_config.d* and concurrent testing via a secondary terminal to avoid administrative lockout of the headless node.
- **BOOT-5122 (GRUB Protection):** Insertion of an encrypted password via PBKDF2 in the boot loader. Requires physical presence or a KVM console in case the credential is forgotten.
- **DEB-0280 and DEB-0810:** Installation of the complementary libraries *libpam-tmpdir* (isolation of user temporary directories) and *apt-listbugs*.
- **NETW-3200:** Definitive blocking of legacy or unnecessary transport protocol modules (DCCP, SCTP, RDS, TIPC) via modprobe, effective at boot.
- **ACCT-9626:** Enabling and historical retention of system accounting metrics through the *sysstat* package.
- **LYNIS:** Update of the Lynis suite binary to the version supported by the upstream repository, eliminating the legacy version warning.

6.3 Low Priority and Informational

Controls that demand monitoring, incremental automations or continuous operational tolerance:

- **LOGG-2190:** Monitoring of deleted in-use file pointers through the *lsuf +L1* utility.
- **FIRE-4513:** Registry analysis of iptables/UFW routing rules to avoid premature disposal of flows destined for containers and applications.
- **FILE-7524:** Continuous refinement of file system access permissions for secondary administrative files.
- **BOOT-5264:** Progressive implementation of isolation directives (sandboxing) in the systemd units of installed services.
- **TOOL-5002:** Creation of centralized routines for periodic and automated execution of Lynis reports.

7. Deliberately Not Applied Controls

In line with the architectural restrictions of the project, the stability of production services took precedence over the dogmatic pursuit of scores in scanning tools. The controls detailed below were analyzed and intentionally discarded:

Control / Directive	Operational Restriction	Real Impact if Executed	Technical Decision
Separate Partitioning (/home, /tmp, /var) — FILE-6310	Monolithic bare-metal server provisioned on a single disk.	Need for complete disassembly, repartitioning and prolonged unavailability.	Discarded. Isolation compensated via logical permission controls and quotas.
Deactivation of the usb-storage Module — USB-1000	The Jellyfin service uses external hard drives via the USB bus for media.	Immediate unfeasibility of reading and streaming the entertainment catalog.	Discarded. Proven functional need.

Module Loading Block (kernel.modules_disabled)	Bare-metal environment subject to continuous compilations and package updates.	Impossibility of compiling modules via DKMS and blocking of new hardware.	Discarded. Maintenance of hardware operational flexibility.
Process Hiding (hidepid=2 on /proc)	The environment runs the Performance Co-Pilot metrics agent (pmcd, pmlogger).	Failure in systemic telemetry collection due to blocked process reading.	Discarded. Preservation of the corporate observability system.
Strict Activation of Secure Boot in Firmware	Headless hardware managed remotely without a dedicated visual interface installed.	Risk of interruption of the boot sequence due to digital signature failures.	Discarded. Limited physical access to the device in case of boot failure.
noexec Directive on the /dev/shm Partition	LAMP stack processes, MariaDB and binaries compiled in dynamic memory.	Instability, thread execution failures and breakage of PHP/Apache operation.	Discarded. Execution requirement shared by server daemons.
Strict Compiler Restriction — HRDN-7222	GCC/Make compilers required for maintenance and dynamic kernel modules.	Immediate breakage of automated peripheral driver update routines.	Discarded. Restricted use mitigated by local execution permissions.
Purge of Locked Accounts — AUTH-9284	Accounts marked as locked belong to system users (mysql, jellyfin).	Operational interruption or startup failure of multiple local daemons.	Discarded. Accounts without interactive shell kept untouched.

8. Lessons Learned

The process of applying defensive cybersecurity principles to active infrastructures enabled the validation of relevant technical lessons for server governance:

- **Security Must Not Compromise Operation:** The hardening process in production environments requires the prior cataloging of all process dependencies. Treating automated audit reports as imperative commands invariably results in service unavailability.
- **Silent Failures in Defense Components:** During the survey of the defensive stack, it was identified that the Fail2ban framework had two active jails (nextcloud and pihole-dns) pointing to nonexistent filter files in the filter.d folder. The tool remained operational, but without effectively blocking the referenced routes. Manual log verification was indispensable to resolve the inconsistency.
- **Secure Validation of Access Mechanisms:** The strict adoption of configuration file syntax checking (*sshd -t*) combined with the persistence of an established primary SSH session acted as an effective safeguard against involuntary operator isolation on a headless server.
- **Defensive Gradualism:** Consistent protection gains can be consolidated with low systemic-risk interventions (such as systemctl adjustments, auditd rules and human password expiration), postponing modifications that require architecture re-engineering to scheduled windows.

9. Conclusion and Next Steps

The project achieved its primary objective of establishing a superior defensive level on the plmnsrv node, raising the system indicator to 80 points and zeroing all vulnerabilities cataloged as critical by the audit engine. The structural

integrity, Caddy proxy communication, Pi-Hole record management and the availability of the Nextcloud and Jellyfin applications were maintained in their entirety throughout the entire modification procedure.

As a sustainment roadmap for the continuous evolution of server governance, the following steps are defined:

4. Execute the low-complexity point actions mapped as high priority (sanitation of the `/etc/hosts` file, update of institutional banners and parameterization of the AIDE SHA hashes).
5. Execute the cleanup of libraries and packages declared orphaned and the removal of legacy kernel image versions through the APT package manager.
6. Establish an automated monthly routine for running the Lynis auditor, storing historical results for compliance analysis and mitigation of configuration drifts.
7. Plan the segregation of log records via a dedicated syslog host in a future phase of local infrastructure expansion, fully meeting the external storage control.